

AUDITORÍA DE FUGA DE DATOS

Evaluación de Privacidad y Mínimo Privilegio (NIST SP 800-53: AC-6)

Autor: Ing. Mauro Alejandro Guadarrama García

Ingeniero en Sistemas Computacionales

Proyecto de Portafolio

Certificado Profesional de Ciberseguridad de Google

Junio 2026

Resumen del Incidente

Un gerente compartió una carpeta interna (con datos de clientes y productos no anunciados) con un representante de éxito de clientes y olvidó revocar el acceso. Posteriormente, debido a un error humano, el representante compartió el enlace de toda la carpeta confidencial con un socio comercial externo. Este socio publicó inadvertidamente el enlace en redes sociales, causando una filtración de datos públicos.

Hoja de Trabajo: Fuga de Datos

Control Analizado	Mínimo privilegio (Least Privilege)
Problema(s)	¿Qué factores contribuyeron a la filtración de información? La filtración ocurrió principalmente porque el gerente no revocó el acceso a la carpeta confidencial una vez que la reunión terminó. Esto, combinado con el error humano del representante al copiar el enlace equivocado, permitió que información altamente sensible saliera del entorno seguro hacia un tercero externo.
Revisión	¿De qué trata NIST SP 800-53: AC-6? El control AC-6 del NIST establece que los usuarios solo deben tener los niveles mínimos de acceso y autorización estrictamente necesarios para cumplir sus tareas. Se enfoca en evitar que los empleados operen con privilegios excesivos, sugiriendo mejoras como restringir el acceso basado en roles, mantener registros de actividad y revocar accesos automáticamente tras un periodo definido.
Recomendación(es)	¿Cómo se podría mejorar el principio de mínimo privilegio en la empresa? 1. Revocar automáticamente el acceso a la información después de un periodo de tiempo específico (por ejemplo, al finalizar un proyecto o reunión).

	2. Restringir el acceso a recursos confidenciales basándose estrictamente en el rol del usuario (RBAC), evitando compartir carpetas completas y limitando el acceso solo a los archivos individuales necesarios.
Justificación	¿Cómo podrían estas mejoras solucionar los problemas? Implementar la revocación automática elimina el riesgo de "olvidos" humanos por parte de los gerentes, asegurando que los enlaces expiren de forma segura. Además, restringir el acceso por roles garantiza que, aunque un empleado cometa un error al compartir un enlace general, el tercero externo no tendrá las credenciales necesarias ni la autorización del sistema para abrir ni visualizar los documentos internos, conteniendo así la filtración de manera proactiva.